

Entregável — Exercício 2.1

Projeto: NovaTech Assistant API | Configuração e Validação de Servidores MCP

1. Mapeamento dos Servidores MCP

Para atender as necessidades do assistente NovaTech e garantir a separação rigorosa de escopos e privilégios de acesso, a arquitetura de contexto local foi estruturada com os seguintes servidores via Model Context Protocol:

- **fs-codigo** : Mapeia as pastas de código-fonte (`./src` e `./tests`), permitindo que o agente autônomo analise, escreva e edite a base de código do *Query Endpoint* de forma independente.
- **fs-leitura** : Mapeia os repositórios de documentação corporativa (`./docs`) e corpus de base de conhecimento para RAG (`./data`). Esse servidor possui escopo estritamente de leitura, fornecendo contexto seguro sobre regras de negócio e SLAs.
- **project-memory** : Servidor de grafo de conhecimento que atua como memória de longo prazo da arquitetura. Permite ao agente registrar, ler e atualizar decisões arquiteturais e padrões de projeto essenciais.

2. Arquivo de Configuração Base (`.mcp/mcp.json`)

O arquivo de configuração abaixo representa o padrão de repositório oficial, formatado com o comando `npx` em escopo global (e sem dados relativos a usuários locais). Isso garante que outros desenvolvedores da equipe que baixarem o repositório possuam a mesma capacidade analítica e acessos parametrizados para os agentes:

```
{
  "mcpServers": {
    "fs-codigo": {
      "command": "npx",
      "args": [
        "-y",
        "@modelcontextprotocol/server-filesystem",
        "./src",
        "./tests"
      ]
    },
    "fs-leitura": {
      "command": "npx",
```

```
    "args": [  
      "-y",  
      "@modelcontextprotocol/server-filesystem",  
      "./docs",  
      "./data"  
    ]  
  },  
  "project-memory": {  
    "command": "npx",  
    "args": [  
      "-y",  
      "@modelcontextprotocol/server-memory"  
    ]  
  }  
}  
}
```

3. Evidências de Execução e Integração

As comprovações a seguir demonstram que o ambiente local e as políticas de bypass foram bem-sucedidos na integração dos servidores locais ao contexto do agente de inteligência artificial:

Evidência A: Leitura de Documentação Corporativa (Filesystem)

O agente utilizou a ferramenta `list_directory` para mapear os arquivos e a ferramenta `read_file` para extrair as diretrizes precisas da Política de Devolução alocada em `./docs/novatech/`.

▼

📄

🗑️

\$0.0000 X

Use as suas ferramentas para listar os arquivos da pasta de documentação (./docs/novatech/) e leia para mim o conteúdo do arquivo que fala sobre a política de devolução.

19.9k 1.0m

0/0 TODOs

m externa, etiqueta de identificação, e conteúdo), e motivo da devolução.

3. O time de atendimento tem 4 horas úteis para triagem do chamado (verificar elegibilidade, documentação e prazo).

4. Se elegível, a coleta reversa é agendada em até 2 dias úteis após aprovação.

5. O reembolso ou crédito é processado em até 5 dias úteis após o recebimento da mercadoria devolvida no centro de distribuição.

3.4. Devoluções parciais

Quando a entrega envolver múltiplos volumes, o cliente pode devolver volumes individuais. Cada volume devolvido segue o mesmo procedimento da seção 3.3. O cálculo de reembolso é proporcional ao peso/valor do volume devolvido, conforme o CT-e.

3.5. Custos de devolução

- Defeito ou erro da NovaTech (carga errada, avaria em trânsito): devolução sem custo para o cliente.
- Desistência do cliente (carga correta, sem defeito): o custo do frete reverso é do cliente, calculado com os mesmos multiplicadores do frete original.
- Prazo expirado (solicitação após 7 dias úteis): não elegível para devolução padrão. Encaminhar ao Comercial para negociação caso a caso.

Thinking...

Captura: O agente lista os documentos e lê a política de devolução do arquivo POL-001.

[Log de Confirmação]

Listei os 6 arquivos da pasta `./docs/novatech/` e li o conteúdo completo do arquivo `POL-001-politica-devolucao.md`, que contém a política de devolução de mercadorias da NovaTech (versão 3.1, atualizada em 15/01/2024). O documento define prazos, exceções, procedimentos, devoluções parciais e custos relacionados ao processo de devolução.

Evidência B: Recuperação de Contexto (RAG via Filesystem)

Demonstração da capacidade analítica do agente na varredura passiva da base de RAG no diretório `./data/retrieval-corpus/`. A resposta exata de resolução e tempo de resposta de SLAs do grupo de clientes *Gold* foi identificada corretamente em formato chunkizado.

Busque nos arquivos da pasta de corpus (./data/retrieval-corpus/) e me diga qual é o SLA de resolução para clientes do tier Gold.

Thinking >

Cline wants to use a tool on the fs-leitura MCP server:

list_directory

Auto-approve

Get a detailed listing of all files and directories in a specified path. Results clearly distinguish between files and directories with [FILE] and [DIR] prefixes. This tool is essential for understanding directory structure and finding specific files within a directory. Only works within allowed directories.

ARGUMENTS

```
{
  "path": "C:/Users/joao.mantovani_ext/OneDrive - Descarbonize Soluções/"
}
```

Response

Plain Text

[FILE] chunks-novatech.md

[FILE] README.md

Thinking...

Captura: Extração e cálculo corretos baseados nos chunks documentados da base de dados.

[Log de Confirmação]

Com base no arquivo `chunks-novatech.md` da pasta `./data/retrieval-corpus/`, encontrei a informação nos `chunks SLA-2024-B` (chamados gerais) e `SLA-2024-C` (incidentes críticos).

SLA para clientes Gold

- **Chamados gerais:** Resolução em até **24 horas úteis** (resposta em até 2h úteis)
- **Incidentes críticos:** Resolução em até **4 horas** (resposta em até 30 min)

Esses prazos constam na tabela de SLA 2024 da NovaTech, onde os clientes são classificados em três tiers: **Gold**, **Silver** e **Standard**.

Evidência C: Escrita e Persistência a Longo Prazo (Project Memory)

O agente invocou as ferramentas `read_graph` e `create_entities` de modo a documentar no banco de dados cognitivo e persistente a principal decisão de arquitetura técnica, associando a dependência entre a infraestrutura do Azure e a modelagem do Zod.



Captura: Registro das entidades "Query Endpoint", "Azure Functions v4" e as devidas dependências documentadas na ADR.

[Log de Confirmação]

A decisão arquitetural foi registrada na memória do projeto (project-memory) com os seguintes elementos:

Entidades criadas:

1. **Query Endpoint** (Component) – Principal endpoint de consulta da NovaTech Assistant API
2. **Azure Functions v4** (Technology) – Runtime serverless para execução das funções
3. **Zod** (Library) – Biblioteca TypeScript para validação de esquemas
4. **ADR-0002-query-endpoint-stack** (Architecture Decision Record) – Registro da decisão arquitetural

Relacionamentos criados:

- Query Endpoint → Azure Functions v4 (uses)
- Query Endpoint → Zod (uses)
- ADR-0002-query-endpoint-stack → Query Endpoint (documents)

Resumo da decisão gravada: "O Query Endpoint usará Azure Functions v4 e validação com Zod", garantindo tipagem segura nas requisições/respostas e integração nativa com o ecossistema serverless Azure. Registrada em 18/06/2026.

4. Análise Crítica de Riscos e Segurança

No desenvolvimento com agentes baseados em ferramentas, especialmente em ecossistemas empresariais locais usando o Model Context Protocol, três principais vetores de vulnerabilidade devem ser geridos:

1. Acesso Indevido a Diretórios Externos (Directory Traversal)

O risco primário onde o agente tenta inferir acesso a arquivos ou componentes confidenciais localizados em repositórios vizinhos, chaves de API, variáveis de ambiente (como `.env`) ou mesmo dados restritos do sistema do usuário hospedeiro.

Mitigação (Aplicada): Utilização da política de escopo fechado do `server-filesystem` do MCP, listando explicitamente o limite em pastas alvo como argumentos de sandbox (`./src` e `./docs`). Nenhum comando externo que saia dessa árvore é interpretado como válido pelo servidor.

2. Sobrescrita e Mutação Acidental de Código Base

Durante tentativas iterativas e autônomas (loops) de resolução de código, há a ameaça do agente deletar artefatos essenciais ou introduzir bugs de maneira oculta se não constrangido devidamente.

Mitigação: Imposição nativa de *Human-in-the-loop* na camada de execução, exigindo aprovação binária humana direta para que ações mutacionais como `write_file` ou comandos de terminal de sistema operacional possam ser performados. E, estruturalmente, separação total entre repositórios restritos de *leitura* (`fs-leitura`) e *escrita* (`fs-codigo`).

3. Exfiltração de Propriedade Intelectual (Vazamento de Contexto)

Dada a natureza de ingestão de arquivos locais inteiros como logs de janela de contexto do LLM, os dados corporativos processados (como chaves soltas no meio do código, credenciais fixadas ou arquiteturas sigilosas) fluem por APIs para treinamento de modelos públicos da nuvem.

Mitigação: Manutenção de provedores com licença *Enterprise/Zero-Retention* (onde modelos proíbem treinamento cruzado de payload processado) ou integração sistemática de ferramentas de DLP (*Data Loss Prevention*) e sanitização baseada em máscaras na pipeline local antes da transmissão.